

OSINT AND RECONNAISSANCE ASSESSMENT REPORT

Damn Vulnerable Web Application (DVWA)

Phase 1 — Open Source Intelligence (OSINT) & Reconnaissance

Document Title	OSINT and Reconnaissance Assessment Report
Version	v1.0
Assessment Phase	Phase 1 of 2 — Reconnaissance
Target Application	Damn Vulnerable Web Application (DVWA)
Target Address	http://127.0.0.1/DVWA/
Assessment Type	Passive OSINT, fingerprinting and enumeration (non-exploitative)
Assessment Date	2 August 2026
Assessor	Abdullah Zubair
Assessment Host	Kali Linux (hostname: parzival)
Classification	Internal — Academic Laboratory Assessment

This assessment was conducted in an isolated laboratory environment against a deliberately vulnerable application. No third-party or production systems were in scope.

Contents

Table of Contents	
1. Executive Summary.....	5
Key Findings	5
Assessment Outcome.....	5
2. Assessment Methodology	6
2.1 Reconnaissance Approach.....	6
2.2 Information Gathering Techniques	6
2.3 Enumeration Procedures	6
2.4 Validation Process	6
2.5 Scope Limitations	7
3. Target Overview	8
3.1 Application Information	8
3.2 Hosting Environment	8
3.3 Network Details.....	8
4. Assessment Requirements and Results	10
4.1 RQ-01 — Target Identification.....	10
Target Profile.....	10
Environment Details	10
4.2 RQ-02 — Technology Fingerprinting.....	10
Technology Stack Inventory.....	10
Security Header Analysis	11
4.3 RQ-03 — Network Reconnaissance.....	12
Command Executed.....	12
Port Enumeration Report	12
Service Inventory.....	13
4.4 RQ-04 — Web Application Enumeration.....	13
Command Executed.....	13
Resource Inventory	13
Endpoint Inventory — Application Functions	14
Vulnerability Module Inventory	14
API Assessment.....	14
4.5 RQ-05 — Information Disclosure Assessment.....	15
4.6 RQ-06 — Attack Surface Mapping	18
Attack Surface Inventory	18

Attack Surface Diagram	19
Severity Rationale	20
5. Findings	21
OSINT-001 — Missing HTTP Security Headers	21
Description	21
Evidence.....	21
Impact.....	21
Recommendations	21
OSINT-002 — Database Service Listening on TCP Port 3306.....	21
Description	22
Evidence.....	22
Impact.....	22
Recommendations	22
OSINT-003 — Exposed Git Repository Metadata.....	22
Description	22
Evidence.....	22
Impact.....	23
Recommendations	23
OSINT-004 — Web Server Version Disclosure.....	23
Description	23
Evidence.....	23
Impact.....	23
Recommendations	23
OSINT-005 — Exposed PHP Configuration File	23
Description	24
Evidence.....	24
Impact.....	24
Recommendations	24
OSINT-006 — Directory Listing Enabled on Sensitive Directories	24
Description	24
Evidence.....	25
Impact.....	25
Recommendations	25
OSINT-007 — HTML Source Comment Disclosure	25
Description	25

Evidence.....	25
Impact.....	25
Recommendations	26
OSINT-008 — Exposed Backup Configuration File	26
Description	26
Evidence.....	26
Impact.....	26
Recommendations	26
OSINT-009 — Exposed Database Resource Files	27
Description	27
Evidence.....	27
Impact.....	27
Recommendations	27
OSINT-010 — JavaScript Comment Disclosure	27
Description	27
Evidence.....	27
Impact.....	28
Recommendations	28
OSINT-011 — Web Crawler Policy Disclosure	28
Description	28
Evidence.....	28
Impact.....	28
Recommendations	28
6. Attack Surface Summary.....	29
Prioritized Attack Chains for Phase 2	29
7. Conclusion.....	29
Preparation for Phase 2.....	30
8. Acceptance Criteria Compliance	30
Appendix A — Evidence Index.....	32
Evidence Handling Notes	32

1. Executive Summary

This report documents the results of a Phase 1 Open Source Intelligence (OSINT) and reconnaissance assessment performed against a locally deployed instance of the Damn Vulnerable Web Application (DVWA). The objective of this phase was to identify publicly accessible information, fingerprint the technology stack, enumerate exposed services and application resources, and construct an attack surface profile that will direct the Phase 2 vulnerability assessment.

All activities were restricted to passive reconnaissance, technology fingerprinting, service discovery, application enumeration and information disclosure analysis. No exploitation, privilege escalation, denial-of-service testing, data modification or automated attack activity was performed, in accordance with the defined scope limitations.

Key Findings

The assessment identified eleven information disclosure and configuration findings: two are assessed as High inherent risk, four as Medium, three as Low and two as Informational. The most significant results are summarised below.

ID	Finding	Inherent Risk
OSINT-003	Exposed Git repository metadata (/DVWA/.git/)	High
OSINT-008	Exposed backup configuration file (config.inc.php.bak)	High
OSINT-002	Database service listening on TCP 3306	Medium
OSINT-005	Exposed PHP configuration file (php.ini)	Medium
OSINT-006	Directory listing enabled on sensitive directories	Medium
OSINT-009	Exposed database resource files (SQL scripts and SQLite databases)	Medium
OSINT-001	Missing HTTP security headers	Low
OSINT-004	Web server version disclosure	Low
OSINT-007	HTML source comment disclosure	Low

The two High-risk findings are significant because each removes a substantial barrier for an attacker. The exposed Git repository permits reconstruction of the complete application source code, converting black-box testing into white-box testing. The exposed backup configuration file is served as plaintext because the .bak extension is not processed by the PHP interpreter, and therefore discloses the database credentials used by the application.

A total of nineteen intentionally vulnerable application modules were catalogued across five vulnerability classes, and ten distinct entry points were recorded in the attack surface entry point matrix. Together these provide a complete and evidence-backed testing scope for Phase 2.

Assessment Outcome

All Phase 1 acceptance criteria have been satisfied. The target environment has been identified, the technology stack fingerprinted, network services enumerated, application resources catalogued, information disclosure analysed, and the attack surface mapped. Every finding in this report is supported by command output or screenshot evidence recorded in Appendix A.

2. Assessment Methodology

2.1 Reconnaissance Approach

The assessment followed a structured, staged approach aligned to the six requirements defined in the Phase 1 specification. Each stage built upon the information recovered in the preceding stage:

- Environment verification — confirm the target and supporting services are operational.
- Technology fingerprinting — identify the server, language, database and client-side technologies.
- Network reconnaissance — enumerate listening ports, services and version banners.
- Application enumeration — discover accessible directories, files and functional endpoints.
- Information disclosure analysis — review discovered resources for sensitive exposure.
- Attack surface mapping — consolidate all results into a prioritised entry point model.

The approach was deliberately non-intrusive. Discovery was performed against a single local host, and every observation was validated by direct request or local inspection before being recorded as a finding.

2.2 Information Gathering Techniques

Technique	Tool / Method	Applied To
Service status verification	systemctl status	Apache, MariaDB
Passive HTTP header analysis	curl -I	login.php, php.ini, config/, database/, .git/
Technology fingerprinting	WhatWeb	http://127.0.0.1/DVWA
Network service discovery	Nmap 7.99 (-sV)	127.0.0.1
Content and directory discovery	dirsearch v0.4.3	http://127.0.0.1/DVWA/
Application configuration review	DVWA setup.php interface	PHP runtime configuration
Source and comment inspection	grep -Rni, find	Web root, JavaScript directory
Browser inspection	Firefox	index.php, setup.php

2.3 Enumeration Procedures

Content discovery was performed with dirsearch using the default wordlist of 11,460 entries, 25 concurrent threads, and the extension set php, aspx, jsp, html and js. Results were filtered to HTTP 200 and 301 responses. Directory structures were then confirmed locally using find, and each discovered resource was independently re-requested with curl to verify that it was genuinely reachable over HTTP rather than merely present on disk.

The nineteen DVWA vulnerability modules were enumerated directly from the application directory structure to ensure the module inventory was complete, as wordlist-based discovery cannot guarantee full coverage.

2.4 Validation Process

Each candidate finding was subjected to a two-step validation before inclusion in this report:

- Reachability confirmation — an HTTP request was issued to the resource and the response status code recorded. Only resources returning HTTP 200 were treated as exposed.
- Content confirmation — where a resource returned 200, its content was retrieved and reviewed to establish what information was actually disclosed, rather than inferring impact from the filename.

This process prevented false positives. For example, the exposed php.ini file advertises permissive directives, but cross-referencing the DVWA setup.php runtime output showed that allow_url_include is in fact Disabled at runtime. This discrepancy is documented in OSINT-005 rather than being reported as a confirmed remote file inclusion condition.

2.5 Scope Limitations

- No exploitation, privilege escalation, denial-of-service or data modification was performed.
- The absence of login rate limiting was not verified, as repeated authentication attempts would constitute active testing outside the Phase 1 scope.
- The Git repository was identified as accessible but was not cloned or reconstructed, as recovery of source code would exceed passive reconnaissance.
- Findings are reported with both inherent risk (the risk the issue would carry in a production deployment) and contextual risk (the risk within this isolated laboratory environment).

Assessor note: during enumeration, dirsearch wrote its output report to /var/www/html/DVWA/config/reports/, a directory inside the web root. This assessor-created artefact is visible in the config/ directory listing evidence and is not a property of the target application. It should be removed before any repeat assessment.

3. Target Overview

3.1 Application Information

Attribute	Value
Application name	Damn Vulnerable Web Application (DVWA)
Application type	Intentionally vulnerable PHP web application
Purpose	Security training, penetration testing practice and tool validation
Target URL	http://127.0.0.1/DVWA/
Application version reference	Git commit d45ba3c4e7efa7f023f25f58ab4af9912c887057
Build date	Saturday 30 May 2026 11:13:16 +0100
Security level at time of test	impossible (observed in the security session cookie)

3.2 Hosting Environment

Attribute	Value
Deployment method	Local web server deployment (Apache document root)
Document root path	/var/www/html/DVWA
Host operating system	Kali Linux (Debian-based)
Hostname	parzival
Environment type	Isolated cybersecurity laboratory environment
Web server	Apache HTTP Server 2.4.68 (Debian)
PHP version	8.4.23
Database server	MariaDB 11.8.8
Assessment platform	Kali Linux (same host, loopback interface)

The assessment host and the target are the same physical machine; testing was conducted across the loopback interface (127.0.0.1). This is relevant to risk interpretation, because services that would be remotely reachable in a production deployment are here bound to localhost only.

3.3 Network Details

Port	State	Service	Version	Protocol
80/tcp	Open	HTTP	Apache httpd 2.4.68 (Debian)	HTTP
3306/tcp	Open	MySQL / MariaDB	MariaDB 11.8.8-MariaDB-1 (Debian)	MySQL protocol

998 further TCP ports were scanned and returned a closed state. No other listening services were identified on the target host.

```
abduallah@parzival: ~/Desktop
Session Actions Edit View Help

(abduallah@parzival): ~/Desktop
$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: disabled)
   Active: active (running) since Sun 2026-08-02 12:16:41 +03; 48s ago
     Invocation: 234e9b3bb2df46a4b57c7eecc1d66774
       Docs: https://httpd.apache.org/docs/2.4/
    Main PID: 17254 (apache2)
      Status: "Total requests: 0; Idle/Busy workers 100/0; Requests/sec: 0; Bytes served/sec: 0 B/sec"
        Tasks: 7 (limit: 6665)
       Memory: 18.9M (peak: 19.5M)
          CPU: 124ms
      CGroup: /system.slice/apache2.service
              └─17254 /usr/sbin/apache2 -k start -DFOREGROUND
                 17257 /usr/sbin/apache2 -k start -DFOREGROUND
                 17258 /usr/sbin/apache2 -k start -DFOREGROUND
                 17259 /usr/sbin/apache2 -k start -DFOREGROUND
                 17260 /usr/sbin/apache2 -k start -DFOREGROUND
                 17261 /usr/sbin/apache2 -k start -DFOREGROUND
                 17263 /usr/sbin/apache2 -k start -DFOREGROUND

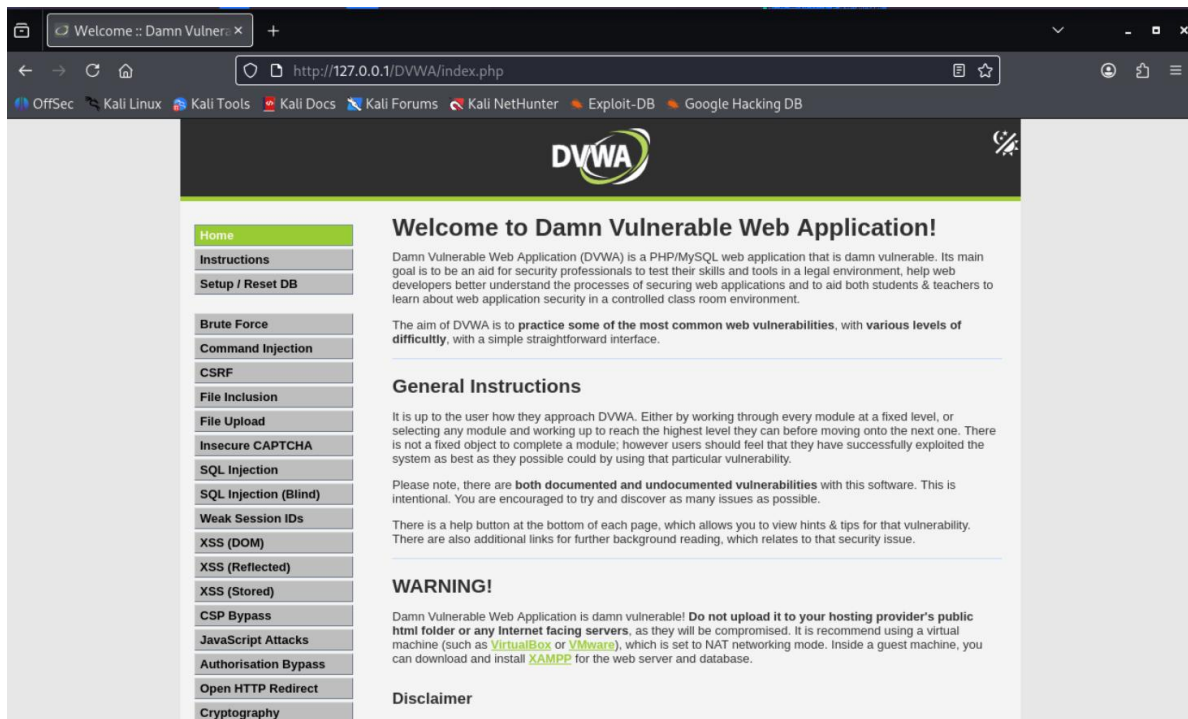
Aug 02 12:16:41 parzival systemd[1]: Starting apache2.service - The Apache HTTP Server...
Aug 02 12:16:41 parzival apachectl[17254]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set t
Aug 02 12:16:41 parzival systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-22/22 (END)
```

Apache HTTP Server 2.4 confirmed active and running (systemctl status apache2).

```
(abduallah@parzival): ~/Desktop
$ sudo systemctl status mariadb
● mariadb.service - MariaDB 11.8.8 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; enabled; preset: disabled)
   Active: active (running) since Sun 2026-08-02 12:18:29 +03; 9s ago
     Invocation: c1c1746901da472fb17b39ded652a522
       Docs: man:mariadb(8)
             https://mariadb.com/kb/en/library/systemd/
    Main PID: 18482 (mariadb)
      Status: "Taking your SQL requests now..."
        Tasks: 16 (limit: 43992)
       Memory: 131.9M (peak: 137.4M)
          CPU: 1.415s
      CGroup: /system.slice/mariadb.service
              └─18482 /usr/sbin/mariadb

Aug 02 12:18:28 parzival mariadb[18482]: 2026-08-02 12:18:28 0 [Note] InnoDB: Loading buffer pool(s) from /var/lib/mysql/ib_buffer_pool
Aug 02 12:18:28 parzival mariadb[18482]: 2026-08-02 12:18:28 0 [Note] Plugin 'FEEDBACK' is disabled.
Aug 02 12:18:28 parzival mariadb[18482]: 2026-08-02 12:18:28 0 [Note] Plugin 'wsrep-provider' is disabled.
Aug 02 12:18:28 parzival mariadb[18482]: 2026-08-02 12:18:28 0 [Note] InnoDB: Buffer pool(s) load completed at 260802 12:18:28
Aug 02 12:18:29 parzival mariadb[18482]: 2026-08-02 12:18:29 0 [Note] Server socket created on IP: '127.0.0.1', port: '3306'.
Aug 02 12:18:29 parzival mariadb[18482]: 2026-08-02 12:18:29 0 [Note] mariadb: Event Scheduler: Loaded 0 events
Aug 02 12:18:29 parzival mariadb[18482]: 2026-08-02 12:18:29 0 [Note] /usr/sbin/mariadb: ready for connections.
Aug 02 12:18:29 parzival mariadb[18482]: Version: '11.8.8-MariaDB-1 from Debian' socket: '/run/mysqld/mysqld.sock' port: 3306 -- Please help get to 10
Aug 02 12:18:29 parzival systemd[1]: Started mariadb.service - MariaDB 11.8.8 database server.
Aug 02 12:18:29 parzival /etc/mysql/debian-start[18511]: Upgrading MariaDB tables if necessary.
lines 1-24/24 (END)
```

MariaDB 11.8.8 confirmed active, listening on 127.0.0.1 port 3306.



DVWA application reachable at <http://127.0.0.1/DVWA/index.php>.

4. Assessment Requirements and Results

This section presents the results for each of the six assessment requirements defined in the Phase 1 specification, together with the deliverables required by each.

4.1 RQ-01 — Target Identification

Objective: identify and document the target environment and deployment details.

Target Profile

Parameter	Details
Application name	Damn Vulnerable Web Application (DVWA)
Application type	Intentionally vulnerable web application
Target URL / IP address	http://127.0.0.1/DVWA/ (127.0.0.1)
Deployment method	Local Apache web server deployment
Environment type	Controlled laboratory environment
Operating system	Kali Linux (Debian-based)
Assessment type	OSINT and reconnaissance (passive, non-exploitative)
Assessment phase	Phase 1
Assessor name	Abdullah
Assessment date	2 August 2026

Environment Details

DVWA is deployed directly within the Apache document root at /var/www/html/DVWA on a Kali Linux host. The application is served over HTTP on port 80 and is backed by a local MariaDB instance on port 3306. The environment is fully isolated: the application binds to the loopback interface and has no exposure to external networks, which is the appropriate configuration for a deliberately vulnerable application.

Deliverables satisfied: Target Profile and Environment Details.

4.2 RQ-02 — Technology Fingerprinting

Objective: identify the technologies used by the application.

Technology Stack Inventory

Component	Identified Technology	Version	Evidence Source
Web server	Apache HTTP Server (Debian)	2.4.68	Nmap, HTTP Server header, WhatWeb
Programming language	PHP	8.4.23	setup.php, .php extensions, PHPSESSID
Database	MariaDB	11.8.8	Nmap banner, systemctl, setup.php
Framework	None identified	—	WhatWeb; no framework signature returned
CMS	None detected	—	WhatWeb; no CMS signature returned

Component	Identified Technology	Version	Evidence Source
Front-end	HTML5, native JavaScript	—	WhatWeb, file inspection
JavaScript files	dvwaPage.js, add_event_listeners.js	—	Directory listing of /DVWA/dvwa/js
Operating system	Debian-based Linux	—	Apache banner, WhatWeb
Session management	PHPSESSID cookie	—	HTTP Set-Cookie header

No PHP framework was identified. Symfony components are present in the application dependency file (vulnerabilities/api/composer.lock) but these are libraries consumed by the API module and do not indicate use of the Symfony framework. Laravel, CodeIgniter and Yii were also checked and were not present.

Security Header Analysis

The HTTP response headers returned by /DVWA/login.php were reviewed for the presence of standard browser security controls.

Security Header	Status	Observation
Content-Security-Policy	Not present	No script source restriction at the response level
X-Frame-Options	Not present	No clickjacking / framing protection
X-Content-Type-Options	Not present	MIME type sniffing not disabled
Strict-Transport-Security	Not present	Not applicable over plain HTTP, but absent
Referrer-Policy	Not present	Referrer information not constrained
Permissions-Policy	Not present	Browser feature access not constrained
Cookie flag: HttpOnly	Present	Set on PHPSESSID and security cookies
Cookie flag: SameSite	Present	SameSite=Strict observed on Set-Cookie
Cookie flag: Secure	Not present	Expected, as the service operates over HTTP

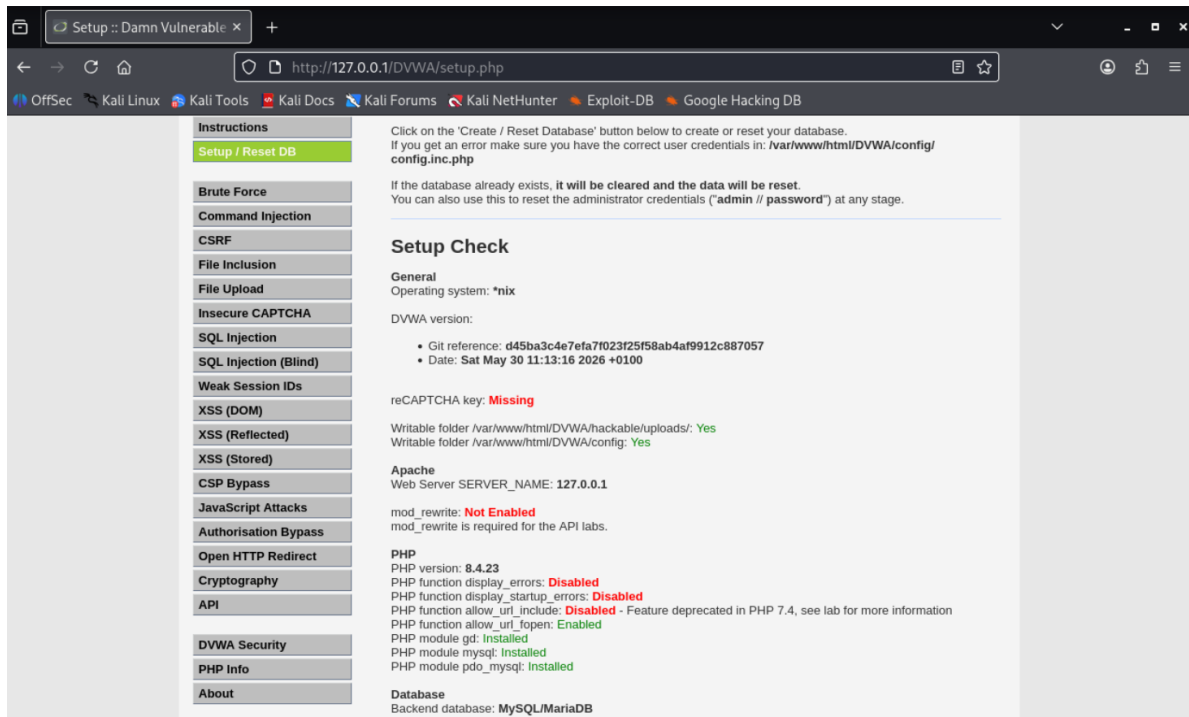
The cookie configuration is notably stronger than the response header configuration: HttpOnly and SameSite=Strict are both applied, which partially mitigates session theft through client-side script and cross-site request contexts.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ whatweb http://127.0.0.1/DVWA
http://127.0.0.1/DVWA [301 Moved Permanently] Apache[2.4.68], Country[RESERVED][XX], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], RedirectLocation[http://127.0.0.1/DVWA/], Title[301 Moved Permanently]
http://127.0.0.1/DVWA/ [302 Found] Apache[2.4.68], Cookies[PHPSESSID,security], Country[RESERVED][XX], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], HttpOnly[PHPSESSID,security], IP[127.0.0.1], RedirectLocation[login.php]
http://127.0.0.1/DVWA/login.php [200 OK] Apache[2.4.68], Country[RESERVED][XX], DVWA, HTML5, HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], PHP, PasswordField[password], Title[Login :: Damn Vulnerable Web Application (DVWA)]
```

WhatWeb fingerprint identifying Apache 2.4.68, Debian Linux, PHP, HTML5 and cookie configuration.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ curl -I http://127.0.0.1/DVWA/login.php
HTTP/1.1 200 OK
Date: Sun, 02 Aug 2026 10:04:05 GMT
Server: Apache/2.4.68 (Debian)
Set-Cookie: security=impossible; path=/; HttpOnly
Set-Cookie: PHPSESSID=[REDACTED] expires=Mon, 03 Aug 2026 10:04:05 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Cache-Control: no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=[REDACTED] expires=Mon, 03 Aug 2026 10:04:05 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
Content-Type: text/html; charset=utf-8
```

HTTP response headers for /DVWA/login.php. Session identifier values were redacted by the assessor.



DVWA setup.php confirming PHP 8.4.23, MySQL/MariaDB backend and runtime PHP configuration.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ curl http://127.0.0.1/DVWA/login.php | grep -i "script"
% Total    % Received % Xferd  Average Speed   Time    Time     Current
                                 Dload  Upload   Total   Spent    Left     Speed
100 1342 100 1342 0 0 0 279.8k 0 0 0 0
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ ls -la /var/www/html/DVWA/dvwa/js
total 16
drwxr-xr-x 2 www-data www-data 4096 Aug 2 12:23 .
drwxr-xr-x 6 www-data www-data 4096 Aug 2 12:23 ..
-rw-r--r-- 1 www-data www-data 593 Aug 2 12:23 add_event_listeners.js
-rw-r--r-- 1 www-data www-data 1240 Aug 2 12:23 dvwaPage.js
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ find /var/www/html/DVWA/dvwa/js -type f
/var/www/html/DVWA/dvwa/js/dvwaPage.js
/var/www/html/DVWA/dvwa/js/add_event_listeners.js
```

Client-side JavaScript inventory: dvwaPage.js and add_event_listeners.js.

Deliverables satisfied: Technology Stack Inventory and Evidence Screenshots.

4.3 RQ-03 — Network Reconnaissance

Objective: identify exposed network services associated with the target.

Command Executed

```
nmap -sV 127.0.0.1
```

Nmap 7.99 was executed at 13:28 (+0300) on 2 August 2026. The scan completed in 17.28 seconds and reported the host as up with 998 closed TCP ports.

Port Enumeration Report

Port	State	Service	Version Detected	Detection Method
80/tcp	Open	http	Apache httpd 2.4.68	Nmap service version detection
3306/tcp	Open	mysql?	MariaDB (unrecognised by signature)	Nmap banner analysis

Service Inventory

Service	Port	Protocol	Banner / Evidence	Exposure
Apache HTTP Server	80/tcp	HTTP	Server: Apache/2.4.68 (Debian)	Serves the DVWA application
MariaDB Database	3306/tcp	MySQL protocol	11.8.8-MariaDB-1 from Debian	Bound to localhost

Nmap was unable to match the port 3306 service against a known signature and returned the service as `mysql?` with a raw fingerprint. The MariaDB version was nonetheless recoverable from the returned banner data, which contained the string `11.8.8-MariaDB-1` from Debian. This was independently corroborated by the MariaDB service status output.

```

[abdullah@parziya]-[/var/www/html/DVWA/config]
└─$ nmap -sV 127.0.0.1
Starting Nmap 7.90 ( https://nmap.org ) at 2026-08-02 13:28 +0300
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000010s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.68
3306/tcp  open  mysql?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3306-TCP:V=7.99%I=7%D=8/2%T=6A6F1B8D%P=x86_64-pc-linux-gnu%r(NUL
SF:1.64,""0\0\0\n11\8\8-MariaDB-1\1x20fom\x20Debian\0\x1d\0\0\x008X47X6
SF:D2\0\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0=0\0\0mp\0(r,"Wwrv9Z\0mysql
SF:native_password\0")%r(GenericLines,9C,""0\0\0\n11\8\8-MariaDB-1\1x20f
SF:rom\x20Debian\0\x1d\0\0\x008X47X6D2\0\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0
SF:0\0\0\0\0mp\0(r,"Wwrv9Z\0mysql_native_password\0x04\0\0\01\xff\x04%
SF:009090909090header\020is\x20not\x20accepted\0_password\0x2027\0\0\0\0
SF:~r(LDAPBindReq,64,""0\0\0\n11\8\8-MariaDB-1\1x20fom\x20Debian\0\0
SF:0\0XMMVTDB\0)\0\xfe\xff-\x02\0\xff\x81\x15\0\0\0\0\0=0\0\0ec\0\0\0V\0\0
SF:0"\"M_\0mysql_native_password\0")%r(afp,64,""0\0\0\n11\8\8-MariaDB-
SF:1\1x20fom\x20Debian\0x008\0\0\0x009fu:aws[\0\0\xfe\xff-\x02\0\xff\x81\x15\
SF:0\0\0\0\0=0\0\0NT>v\0\0G-Ks%OG\0mysql_password\0")
Service Info: Host: 127.0.0.1
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.28 seconds

```

Nmap service version scan identifying ports 80 and 3306 with the MariaDB banner visible in the fingerprint.

Deliverables satisfied: Port Enumeration Report, Service Inventory and Supporting Evidence.

4.4 RQ-04 — Web Application Enumeration

Objective: enumerate accessible resources and application functionality.

Command Executed

```
sudo dirsearch -u http://127.0.0.1/DVWA/
```

dirsearch v0.4.3 — extensions: php, aspx, jsp, html, js | HTTP method: GET | threads: 25 | wordlist size: 11,460.

Resource Inventory

Resource	Status	Classification	Description
/DVWA/login.php	200	Authentication	User authentication portal
/DVWA/setup.php	200	Administrative	Database creation and reset interface
/DVWA/index.php	200	Application	Application home page
/DVWA/config/	200	Configuration	Configuration directory, listing enabled
/DVWA/database/	200	Data store	Database resources, listing enabled
/DVWA/docs/	200	Documentation	Application documentation
/DVWA/dvwa/	200	Application	Core application resources including js/
/DVWA/hackable/	Existing	Application	Training resources and upload targets
/DVWA/tests/	200	Development	Testing resources

Resource	Status	Classification	Description
/DVWA/vulnerabilities/	Existing	Application	Vulnerability module root (19 modules)
/DVWA/php.ini	200	Configuration	PHP configuration file, readable
/DVWA/robots.txt	200	Information	Crawler policy
/DVWA/security.txt	200	Information	Security contact information file
/DVWA/.git/	200	Source control	Git repository metadata, readable
/DVWA/.dockerignore	200	Development	Container build exclusion file

Endpoint Inventory — Application Functions

Component Type	Location	Purpose
Login portal	/DVWA/login.php	Primary authentication entry point
Session management	PHPSESSID cookie	Session state handling
Administrative interface	/DVWA/setup.php	Database creation and credential reset
Security level control	/DVWA/security.php	Application security level configuration
Instructions interface	/DVWA/instructions.php	Application usage documentation
File upload component	/DVWA/vulnerabilities/upload/	File upload handling
API component	/DVWA/vulnerabilities/api/	API module with composer dependencies
Input interfaces	sql_i, xss_r, xss_s, exec, brute	User-supplied input processing

Note on registration and password reset: DVWA does not implement a public user registration page or a password reset workflow. Credential state is managed exclusively through setup.php, which resets the administrator account to its default values. This absence is recorded so that the authentication attack surface is not overstated.

Vulnerability Module Inventory

The nineteen vulnerability modules present under /DVWA/vulnerabilities/ were enumerated directly from the directory structure and grouped by vulnerability class.

Class	Modules	Count
Injection	sql_i, sql_i_blind, exec, fi	4
Client side	xss_r, xss_s, xss_d, javascript, csp	5
Access control	bac, authbypass, weak_id	3
Authentication	brute, captcha	2
Other	csrf, api, upload, open_redirect, cryptography	5

API Assessment

An API module was identified at /DVWA/vulnerabilities/api/. The module directory contains a composer.lock dependency file. No formal API documentation, OpenAPI specification or enumerable endpoint index was discovered during passive enumeration. Detailed API endpoint discovery, request method testing and response format analysis require authenticated interaction and are therefore deferred to Phase 2.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ sudo dirsearch -u http://127.0.0.1/DVWA/
/usr/lib/python3/dist-packages/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /var/www/html/DVWA/config/reports/http_127.0.0.1_DVWA_26-08-02_13-35-21.txt
Target: http://127.0.0.1/

[13:35:21] Starting: DVWA/
[13:35:21] 200 - 808 - /DVWA/.dockerignore
[13:35:22] 301 - 3508 - /DVWA/.git → http://127.0.0.1/DVWA/.git/
[13:35:22] 200 - 6878 - /DVWA/.git/
[13:35:22] 200 - 738 - /DVWA/.git/description
[13:35:22] 200 - 2628 - /DVWA/.git/config
[13:35:22] 200 - 238 - /DVWA/.git/HEAD
[13:35:22] 200 - 7938 - /DVWA/.git/hooks/
[13:35:22] 200 - 5578 - /DVWA/.git/info/
[13:35:22] 200 - 27KB - /DVWA/.git/index
[13:35:22] 200 - 2408 - /DVWA/.git/info/exclude
[13:35:22] 200 - 1778 - /DVWA/.git/logs/HEAD
[13:35:22] 200 - 5798 - /DVWA/.git/logs/
[13:35:22] 301 - 3608 - /DVWA/.git/logs/refs → http://127.0.0.1/DVWA/.git/logs/refs/
[13:35:22] 301 - 3668 - /DVWA/.git/logs/refs/heads → http://127.0.0.1/DVWA/.git/logs/refs/heads/
[13:35:22] 200 - 1778 - /DVWA/.git/logs/refs/heads/master
[13:35:22] 301 - 3688 - /DVWA/.git/logs/refs/remotes → http://127.0.0.1/DVWA/.git/logs/refs/remotes/
[13:35:22] 200 - 1778 - /DVWA/.git/logs/refs/remotes/origin/HEAD
[13:35:22] 301 - 3758 - /DVWA/.git/logs/refs/remotes/origin → http://127.0.0.1/DVWA/.git/logs/refs/remotes/origin/
[13:35:22] 200 - 5628 - /DVWA/.git/objects/
[13:35:22] 200 - 8378 - /DVWA/.git/packed-refs
[13:35:22] 200 - 5708 - /DVWA/.git/refs/
[13:35:22] 200 - 418 - /DVWA/.git/refs/heads/master
[13:35:22] 301 - 3618 - /DVWA/.git/refs/heads → http://127.0.0.1/DVWA/.git/refs/heads/
[13:35:22] 301 - 3638 - /DVWA/.git/refs/remotes → http://127.0.0.1/DVWA/.git/refs/remotes/
[13:35:22] 200 - 328 - /DVWA/.git/refs/remotes/origin/HEAD
[13:35:22] 301 - 3708 - /DVWA/.git/refs/remotes/origin → http://127.0.0.1/DVWA/.git/refs/remotes/origin/
```

dirsearch content discovery, showing extensive Git repository metadata exposure.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ cat /var/www/html/DVWA/robots.txt
User-agent: *
Disallow: /

(abdullah@parzival)-[/var/www/html/DVWA/config]
$ find /var/www/html/DVWA/vulnerabilities -maxdepth 1 -type d
/var/www/html/DVWA/vulnerabilities
/var/www/html/DVWA/vulnerabilities/bac
/var/www/html/DVWA/vulnerabilities/csrf
/var/www/html/DVWA/vulnerabilities/api
/var/www/html/DVWA/vulnerabilities/exec
/var/www/html/DVWA/vulnerabilities/brute
/var/www/html/DVWA/vulnerabilities/upload
/var/www/html/DVWA/vulnerabilities/fi
/var/www/html/DVWA/vulnerabilities/open_redirect
/var/www/html/DVWA/vulnerabilities/xss_d
/var/www/html/DVWA/vulnerabilities/xss_r
/var/www/html/DVWA/vulnerabilities/sqli_blind
/var/www/html/DVWA/vulnerabilities/authbypass
/var/www/html/DVWA/vulnerabilities/xss_s
/var/www/html/DVWA/vulnerabilities/weak_id
/var/www/html/DVWA/vulnerabilities/sqli
/var/www/html/DVWA/vulnerabilities/captcha
/var/www/html/DVWA/vulnerabilities/csp
/var/www/html/DVWA/vulnerabilities/javascript
/var/www/html/DVWA/vulnerabilities/cryptography
```

robots.txt contents and enumeration of the nineteen vulnerability module directories.

Deliverables satisfied: Resource Inventory, Endpoint Inventory and Evidence Repository.

4.5 RQ-05 — Information Disclosure Assessment

Objective: identify publicly accessible information that may expose sensitive implementation details.

Eleven information disclosure conditions were identified and validated. Each is documented in full in Section 5 (Findings). The table below summarises the disclosure categories assessed and the result of each check.

Category	Check Performed	Result	Finding
Source code information	HTML comment inspection	Disclosed	OSINT-007
Source code information	JavaScript comment inspection	Disclosed	OSINT-010
Source code information	Developer notes in source	Disclosed	OSINT-007
Configuration exposure	robots.txt	Present, low value	OSINT-011
Configuration exposure	sitemap.xml	Not present	No finding

Category	Check Performed	Result	Finding
Configuration exposure	Backup file discovery	Disclosed	OSINT-008
Configuration exposure	Configuration file access	Disclosed	OSINT-005, 006
Error handling	Stack traces and debug output	Not observed	No finding
Metadata	Framework signatures	None present	No finding
Metadata	Build and version information	Disclosed	OSINT-003, 004
Metadata	Server banner	Disclosed	OSINT-004

Error handling was assessed by reviewing the application configuration rather than by inducing errors, since deliberately triggering application faults would exceed passive testing. The setup.php runtime output confirms that display_errors and display_startup_errors are both Disabled, indicating that verbose PHP errors are not returned to the browser by default.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ curl -I http://127.0.0.1/DVWA/.git/
HTTP/1.1 200 OK
Date: Sun, 02 Aug 2026 10:54:37 GMT
Server: Apache/2.4.68 (Debian)
Content-Type: text/html; charset=UTF-8
```

Validation that /DVWA/.git/ returns HTTP 200 OK.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ curl -I http://127.0.0.1/DVWA/php.ini
HTTP/1.1 200 OK
Date: Sun, 02 Aug 2026 10:56:25 GMT
Server: Apache/2.4.68 (Debian)
Last-Modified: Sun, 02 Aug 2026 09:23:27 GMT
ETag: "9a-6580cf96653ae"
Accept-Ranges: bytes
Content-Length: 154

(PURPLE)

$ curl http://127.0.0.1/DVWA/php.ini
; This file attempts to overwrite the original php.ini file. Doesnt always work.

magic_quotes_gpc = Off
allow_url_fopen = on
allow_url_include = on
```

php.ini accessible over HTTP (154 bytes) with full directive contents disclosed.

```
(abdullah@parzival)-[/var/www/html/DVWA/config]
$ curl -I http://127.0.0.1/DVWA/config/
HTTP/1.1 200 OK
Date: Sun, 02 Aug 2026 10:59:24 GMT
Server: Apache/2.4.68 (Debian)
Content-Type: text/html; charset=UTF-8
```

Validation that /DVWA/config/ returns HTTP 200 OK.

```
(abdu1lah@parzival)-[/var/www/html/DVWA/config]
$ curl -I http://127.0.0.1/DVWA/database/
HTTP/1.1 200 OK
Date: Sun, 02 Aug 2026 10:59:29 GMT
Server: Apache/2.4.68 (Debian)
Content-Type: text/html; charset=UTF-8
```

Validation that /DVWA/database/ returns HTTP 200 OK.

```
[abdullah@parzival]~$ var/www/html/DVWA/config/
$ curl http://127.0.0.1/DVWA/config/
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Index of /DVWA/config</title>
</head>
<body>
<h1>Index of /DVWA/config/h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">>Last modified</a></th><th>
<a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">>Description</a></th></tr>
<tr><th colspan="5"><hr /></th></tr>
<tr><td valign="top"></td><td><a href="/DVWA/">Parent Directory</a></td><td>&nbsp;</td><td align="right">-
</td><td>&nbsp;</td></tr>
<tr><td valign="top"></td><td><a href="config.inc.php">config.inc.php</a></td><td align="right">2026-08-02 12:3
9</td><td align="right">2.4K</td><td>&nbsp;</td></tr>
<tr><td valign="top"></td><td><a href="config.inc.php.bak">config.inc.php.bak</a></td><td align="right">2026-08
-02 12:39</td><td align="right">2.4K</td><td>&nbsp;</td></tr>
<tr><td valign="top"></td><td><a href="config.inc.php.dist">config.inc.php.dist</a></td><td align="right">2026-08
02 12:23</td><td align="right">2.4K</td><td>&nbsp;</td></tr>
<tr><td valign="top"></td><td><a href="reports/">reports/</a></td><td align="right">2026-08-02 13:35</td><td>
lign="right">-</td><td>&nbsp;</td></tr>
<tr><th colspan="5"><hr /></th></tr>
</table>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 80</address>
</body></html>
```

Directory index of /DVWA/config/ exposing config.inc.php.bak and related files.

```
[abdulrah@parvati:~]-[var/www/html/DVWA/config]
$ curl http://127.0.0.1/DVWA/database/
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
  <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
  <title>Index of /DVWA/database</title>
</head>
<body>
<h1>Index of /DVWA/database/<h1>
  <table>
    <tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
    <tr><th colspan="5"><hr /></th></tr>
    <tr><td valign="top"></td><td><a href="/DVWA/">Parent Directory</a></td><td align="right"> -
      </td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="bac_setup.sql">bac_setup.sql</a></td><td align="right">2026-08-02 12:23
      </td><td align="right">1.0K</td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="create_mssql_db.sql">create_mssql_db.sql</a></td><td align="right">2026-
      08-02 12:23 </td><td align="right">1.1K</td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="create_oracle_db.sql">create_oracle_db.sql</a></td><td align="right">202
      6-08-02 12:23 </td><td align="right">1.1K</td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="create_postgresql_db.sql">create_postgresql_db.sql</a></td><td align="ri
      ght">2026-08-02 12:23 </td><td align="right">1.810 </td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="create_sqlite_db.sql">create_sqlite_db.sql</a></td><td align="right">202
      6-08-02 12:23 </td><td align="right">945 </td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="sqli.db">sqli.db</a></td><td align="right">2026-08-02 12:23 </td><td al
      ign="right">20K</td><td align="right"></td></tr>
    <tr><td valign="top"></td><td><a href="sqli.db.dist">sqli.db.dist</a></td><td align="right">2026-08-02 12:23 <
      /td><td align="right">20K</td><td align="right"></td></tr>
    <tr><th colspan="5"><hr /></th></tr>
  </table>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 80</address>
</body></html>
```

Directory index of /DVWA/database/ exposing SQL scripts and SQLite database files.

```

[abdulrah@parvizal]-[/var/www/html/DVWA/config]
[?] grep -rni '4←=' /var/www/html/DVWA | head
/var/www/html/DVWA/hackable/flags/flag.php:24:4←= 5.) The world isn't run by weapons anymore, or energy, or money. It's run by little ones and zeroes, little bits of data. It's all just electrons.
/var/www/html/DVWA/setup/setup.php:160:4←= Create db button →
/var/www/html/DVWA/vulnerabilities/bac/source/low.php:46:4←= Hint: Cookies can be modified by users... →
/var/www/html/DVWA/vulnerabilities/bac/source/high.php:60:4←= Hint: Session management is better, but still vulnerable... →
/var/www/html/DVWA/vulnerabilities/bac/source/medium.php:39:4←= Hint: This token check isn't very secure... →
/var/www/html/DVWA/vulnerabilities/bac/source/medium.php:46:$html .= "<p>Access denied. Valid token required. 4←= Try using token = user_token -><p>";
/var/www/html/DVWA/vulnerabilities/fix/fix4.php:11:4←= You did an even better job to see this :-!) →
/var/www/html/DVWA/vulnerabilities/captcha/index.php:75:$page[ 'body' ] .= "\n\n4←= **DEV NOTE** Response: 'hidd3n_valu366 User-Agent: 'reCAPTCHA' **DEV NOTE**>\n\n";
/var/www/html/DVWA/dvwa/includes/Parsedown.php:410:if (strpos($line['text'], '4←=') == 0)
/var/www/html/DVWA/dvwa/includes/Parsedown.php:1478:if ($excerpt['text'][1] == '!' and preg_match('/^<!--?>(<?>|<?>|<?>)*>|s', $excerpt['text'], $matches))

```

HTML comment disclosure across application source, including developer hint notes.

```
(abdullah@parzival)-[var/www/html/DVWA/config]
$ grep -Rni "/*" /var/www/html/DVWA/dvwa/js
/var/www/html/DVWA/dvwa/js/dvwaPage.js:7: //eval("page" + id + " = window.open(URL, '' + id + '', 'toolbar=0,scrollbars=1,location=0,statusbar=0,menu
bar=0,resizable=1,width=800,height=300,left=540,top=250');");
/var/www/html/DVWA/dvwa/js/dvwaPage.js:27: // Guestbook form
/var/www/html/DVWA/dvwa/js/add_event_listeners.js:1: // These functions need to be called after the content they reference
/var/www/html/DVWA/dvwa/js/add_event_listeners.js:2: // has been added to the page otherwise they will fail.
(abdullah@parzival)-[var/www/html/DVWA/config]
$ find /var/www/html/DVWA -type f \( -name "*.bak" -o -name "*.old" -o -name "*~" \)
/var/www/html/DVWA/config/config.inc.php.bak
```

JavaScript comment disclosure and backup file discovery via find.

Deliverables satisfied: Information Disclosure Findings, Risk Assessment (Section 5) and Evidence.

4.6 RQ-06 — Attack Surface Mapping

Objective: identify all accessible components that may become targets during security testing.

Attack Surface Inventory

Category	Component	Location	Present
Authentication	Login page	/DVWA/login.php	Yes
Authentication	Registration page	—	Not implemented
Authentication	Password reset function	—	Not implemented
Authentication	Session management	PHPSESSID cookie	Yes
Input interfaces	SQL injection input forms	/vulnerabilities/sqli, sqli_blind	Yes
Input interfaces	Command execution input	/vulnerabilities/exec	Yes
Input interfaces	Reflected and stored input	/vulnerabilities/xss_r, xss_s, xss_d	Yes
Input interfaces	Guestbook / feedback form	/vulnerabilities/xss_s	Yes
Input interfaces	Brute force login form	/vulnerabilities/brute	Yes
File handling	File upload component	/vulnerabilities/upload	Yes
File handling	File inclusion component	/vulnerabilities/fi	Yes
API components	API module	/vulnerabilities/api	Yes
Administrative	Database setup / reset	/DVWA/setup.php	Yes
Administrative	Security level control	/DVWA/security.php	Yes
Administrative	PHP configuration view	/DVWA/phpinfo.php (via PHP Info menu)	Yes

The attack surface map and entry point matrix that follow consolidate these components with the network services and information disclosure findings into a single prioritised model. Entry point identifiers (NET-01, AS-01 and so on) are used consistently across both diagrams and Section 6.

Deliverables satisfied: Attack Surface Inventory, Entry Point Matrix and Attack Surface Diagram.

Attack Surface Diagram

DVWA attack surface map showing the trust boundary, network service layer and five application entry point surfaces with severity ratings.

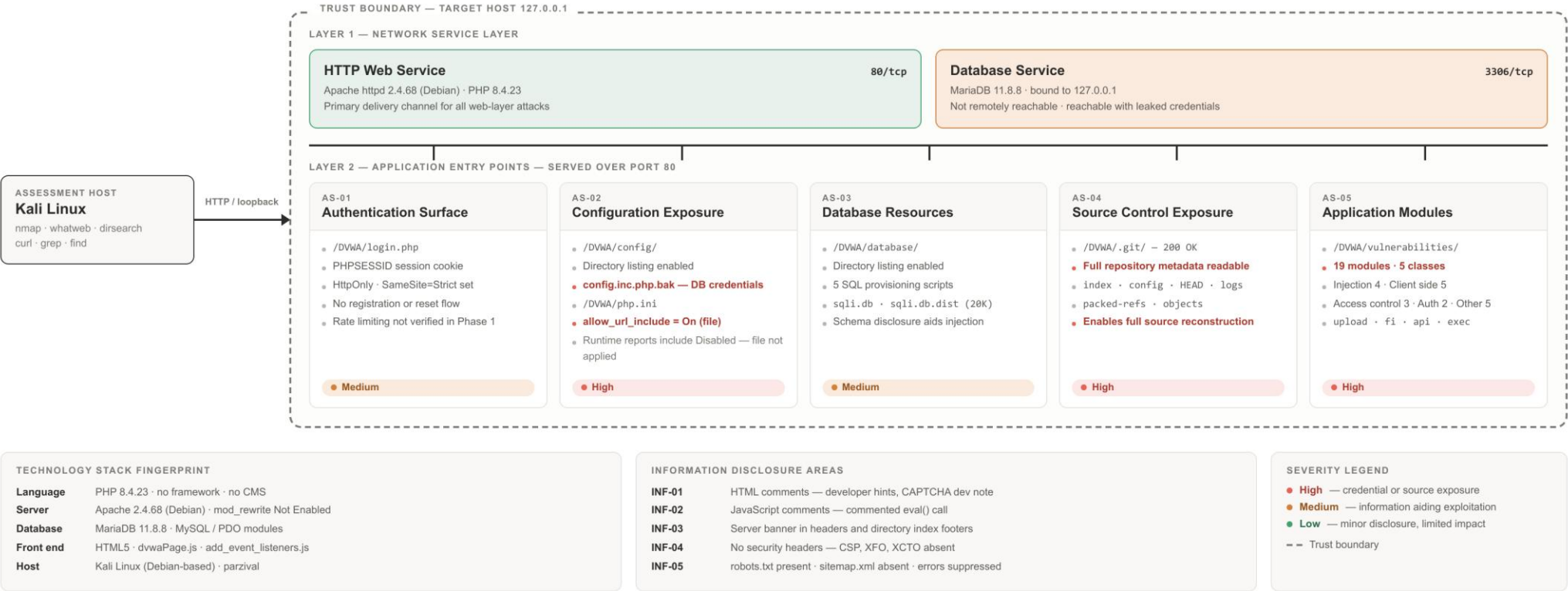
DVWA — Attack Surface Map

RQ-06 · Phase 1 OSINT & Reconnaissance Assessment · Passive and unauthenticated enumeration

SCOPE
127.0.0.1
/DVWA

METHOD
Passive
Non-exploitative

SURFACE NODES
7 mapped
2 network · 5 application



DVWA Attack Surface Entry Point Matrix

RQ-06 · Phase 1 OSINT & Reconnaissance Assessment · Companion to the Attack Surface Map

The matrix below catalogues every entry point identified during Phase 1. Severity reflects inherent risk. Ten entry points were catalogued: three High, six Medium and one Low, spanning two network services and eight application-layer surfaces

ID	Entry Point	Type	Technology	Exposure Observed	Severity	Attack Relevance / Phase 2 Follow-up
NET-01	80/tcp HTTP web service	Network	Apache 2.4.68 (Debian)	Open and serving the application; exact version disclosed in the Server header	Medium	Primary delivery channel for all web attacks. Check vendor advisories against Apache 2.4.68; suppress the banner via ServerTokens Prod.
NET-02	3306/tcp Database service	Network	MariaDB 11.8.8	Open; bound to 127.0.0.1. Version and distribution disclosed in the service banner	Medium	Not remotely reachable, so impact is limited. Becomes critical if the credentials from AS-02b are valid and the bind address is widened.
AS-01	/DVWA/login.php Login interface	Authentication	PHP · PHPSESSID cookie	Unauthenticated form; HttpOnly and SameSite=Strict applied. No registration or password reset flow exists	Medium	Credential attack surface. Test for rate limiting and account lockout in Phase 2; not verified passively. Modules: brute, authbypass, weak_id.
AS-02a	/DVWA/config/ Configuration directory	Configuration	Apache directory index	Directory listing enabled; returns HTTP 200 OK and enumerates all contained files	Medium	Enables discovery of the backup file below. Disable indexing via the Apache Options directive.
AS-02b	config.inc.php.bak Backup configuration file	Configuration	Plaintext PHP source	Served as plaintext because .bak is not mapped to the PHP interpreter; discloses database credentials	High	Direct credential disclosure. Feeds NET-02 for authenticated database access. Highest-value finding of Phase 1.
AS-02c	/DVWA/php.ini PHP configuration	Configuration	PHP runtime directives	allow_url_include = On, allow_url_fopen = on, magic_quotes_gpc = Off	Medium	File advertises permissive directives, but setup.php reports allow_url_include as Disabled at runtime, so this file is not applied. Confirm the effective configuration in Phase 2 before inclusion testing.
AS-03	/DVWA/database/ Database resources	Data store	SQL scripts · SQLite	Listing enabled; five provisioning scripts plus sqli.db and sqli.db.dist downloadable	Medium	Schema disclosure removes guesswork from injection testing. Build targeted payloads from the recovered table and column names. Modules: sqli, sqli_blind.
AS-04	/DVWA/.git/ Source control metadata	Source code	Git repository	Returns HTTP 200 OK. Index, config, HEAD, packed-refs, logs and object store all readable	High	Full application source can be reconstructed, converting black-box testing into white-box review. Also exposes deleted files and commit history.
AS-05	/DVWA/vulnerabilities/ Application modules	Application	PHP module endpoints	Nineteen distinct vulnerable modules across five classes, including file upload, file inclusion and API components	High	Core Phase 2 testing scope. Prioritise the injection and file handling modules; the API module requires authenticated enumeration.
INF-01	HTML source comments Application-wide	Disclosure	HTML5 rendered output	Developer hints and a hard-coded CAPTCHA response value present in client-visible source	Low	Minor in isolation, but useful for identifying internal naming, paths and intended functionality. Modules: captcha, bac, fi.

Severity Rationale

- High — leads directly to credential disclosure, source code recovery, or the exploitable core of the application.
- Medium — provides information that measurably reduces the effort required to exploit another weakness.
- Low — minor disclosure with limited standalone value to an attacker.

5. Findings

Each finding is presented in the format required by the Phase 1 specification. Two risk values are given for each: the inherent risk the condition would carry in a production deployment, and the contextual risk within this isolated laboratory environment. Inherent risk should be used when prioritising remediation guidance; contextual risk reflects actual exposure here.

OSINT-001 — Missing HTTP Security Headers

Finding ID	OSINT-001	Inherent Risk	Low
Category	Information Disclosure	Contextual Risk	Low

Description

The application does not return standard HTTP security response headers. Analysis of the response from /DVWA/login.php confirmed the absence of Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy. Session cookies are, however, correctly configured with the HttpOnly and SameSite=Strict attributes.

Evidence

```
$ curl -I http://127.0.0.1/DVWA/login.php
HTTP/1.1 200 OK
Server: Apache/2.4.68 (Debian)
Set-Cookie: security=impossible; path=/; HttpOnly; SameSite=Strict
Set-Cookie: PHPSESSID=[redacted]; path=/; HttpOnly; SameSite=Strict
Cache-Control: no-cache, must-revalidate
Content-Type: text/html; charset=utf-8
# No Content-Security-Policy, X-Frame-Options or X-Content-Type-Options returned
```

Impact

The absence of these headers removes defence-in-depth protections that browsers would otherwise enforce. Without X-Frame-Options or a frame-ancestors directive the application may be framed by a third-party site, enabling clickjacking. Without X-Content-Type-Options browsers may perform MIME type sniffing. Without a Content-Security-Policy there is no response-level restriction on script execution sources, which increases the impact of any cross-site scripting vulnerability.

Recommendations

- Implement Content-Security-Policy with an explicit script-src directive.
- Add X-Frame-Options: DENY or a CSP frame-ancestors directive.
- Add X-Content-Type-Options: nosniff.
- Add Referrer-Policy: strict-origin-when-cross-origin.
- Apply the Secure cookie attribute once the application is served over HTTPS.

OSINT-002 — Database Service Listening on TCP Port 3306

Finding ID	OSINT-002	Inherent Risk	Medium
Category	Information Disclosure	Contextual Risk	Low

Description

Network reconnaissance identified an active MariaDB database service listening on TCP port 3306. The service returned banner data disclosing the exact database version and distribution. The service status output confirms the listener is bound to the loopback address 127.0.0.1.

Evidence

```
$ nmap -sV 127.0.0.1
PORT      STATE SERVICE VERSION
80/tcp    open  http   Apache httpd 2.4.68
3306/tcp  open  mysql?
# Banner recovered from service fingerprint:
11.8.8-MariaDB-1 from Debian
```

Impact

Disclosure of the precise database version allows an attacker to identify version-specific vulnerabilities without further probing. In this deployment the service is bound to localhost, so it is not reachable from other hosts and the practical exposure is limited. If the bind address were widened, or if valid credentials were obtained from another finding such as OSINT-008, this service would provide direct access to application data while bypassing all application-layer controls.

Recommendations

- Keep the MariaDB listener bound to 127.0.0.1 unless remote access is explicitly required.
- Where remote access is required, restrict source addresses using firewall rules.
- Enforce strong, unique credentials for all database accounts.
- Restrict database version disclosure where the deployment supports it.

OSINT-003 — Exposed Git Repository Metadata

Finding ID	OSINT-003	Inherent Risk	High
Category	Information Disclosure	Contextual Risk	Medium

Description

The Git version control directory is publicly accessible over HTTP at /DVWA/.git/. Content discovery enumerated a large number of readable repository objects including the repository index, configuration, HEAD reference, packed references, commit logs and branch references. Direct validation confirmed the directory returns HTTP 200 OK.

Evidence

```
$ curl -I http://127.0.0.1/DVWA/.git/
HTTP/1.1 200 OK
Server: Apache/2.4.68 (Debian)
Content-Type: text/html; charset=UTF-8
# Representative resources enumerated by dirsearch:
200 - 687B - /DVWA/.git/
200 - 262B - /DVWA/.git/config
200 - 23B - /DVWA/.git/HEAD
200 - 27KB - /DVWA/.git/index
200 - 837B - /DVWA/.git/packed-refs
200 - 177B - /DVWA/.git/logs/HEAD
```

Impact

An accessible Git repository permits reconstruction of the complete application source code, including files that were deleted or modified in earlier commits. This transforms a black-box assessment into a white-box assessment and may expose credentials, API keys or internal hostnames committed at any point in the repository history. The commit logs additionally reveal developer identities and development timelines. This is the highest-value reconnaissance finding identified in this assessment.

Recommendations

- Remove .git directories from all web-accessible deployment paths.
- Deploy application code using an export or build artefact rather than a repository clone.
- Configure the web server to deny access to hidden files, for example: RedirectMatch 404 /\.git
- Rotate any credential that has ever been committed to the repository history.

OSINT-004 — Web Server Version Disclosure

Finding ID	OSINT-004	Inherent Risk	Low
Category	Information Disclosure	Contextual Risk	Low

Description

The Apache HTTP Server returns its precise version number and host distribution in the Server response header on every response. The same information is independently disclosed through the Nmap service banner and through the signature block appended to generated directory index pages.

Evidence

```
$ curl -I http://127.0.0.1/DVWA/login.php
Server: Apache/2.4.68 (Debian)
```

```
# Also disclosed in directory index footers:
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 80</address>
```

Impact

Precise version disclosure allows an attacker to map the server against published vulnerability databases and identify version-specific exploits without sending additional probing requests. It also confirms the underlying operating system family, which assists in selecting appropriate payloads and file paths during later testing phases.

Recommendations

- Set ServerTokens Prod to limit the Server header to the product name only.
- Set ServerSignature Off to remove the signature from generated pages.
- Consider removing the Server header entirely at a reverse proxy where one is present.

OSINT-005 — Exposed PHP Configuration File

Finding ID	OSINT-005	Inherent Risk	Medium
Category	Information Disclosure	Contextual Risk	Low

Description

A PHP configuration file is directly readable over HTTP at /DVWA/php.ini. The file is served as plaintext and discloses three PHP directives. Cross-validation against the DVWA setup.php runtime output established that these directives are not actually in effect, which is documented here to avoid overstating the finding.

Evidence

```
$ curl -I http://127.0.0.1/DVWA/php.ini
HTTP/1.1 200 OK
Server: Apache/2.4.68 (Debian)
Content-Length: 154
```

```
$ curl http://127.0.0.1/DVWA/php.ini
; This file attempts to overwrite the original php.ini file. Doesnt always work.
magic_quotes_gpc = Off
allow_url_fopen = on
allow_url_include = on
```

Runtime configuration reported by setup.php: PHP version 8.4.23, allow_url_include Disabled, allow_url_fopen Enabled, display_errors Disabled, display_startup_errors Disabled.

Impact

Exposure of configuration files discloses details of the PHP execution environment that assist an attacker in selecting attack techniques. In this instance the disclosed directives suggest that remote file inclusion would be viable. However, the authoritative runtime configuration reported by setup.php shows allow_url_include as Disabled and allow_url_fopen as Enabled, confirming that this file is not being applied by the PHP interpreter. The practical impact is therefore limited to information disclosure, and any file inclusion testing in Phase 2 should assume local inclusion only until the effective configuration is re-verified.

Recommendations

- Remove configuration files from web-accessible directories.
- Deny direct access to .ini files, for example with a FilesMatch ".ini\$" rule requiring all denied.
- Store runtime configuration outside the document root.
- Remove configuration files that have no effect, as they create misleading documentation of the security posture.

OSINT-006 — Directory Listing Enabled on Sensitive Directories

Finding ID	OSINT-006	Inherent Risk	Medium
Category	Information Disclosure	Contextual Risk	Medium

Description

Apache directory indexing is enabled on two sensitive application directories, /DVWA/config/ and /DVWA/database/. Requesting either path returns a generated index page enumerating the full contents of the directory together with file sizes and modification timestamps.

Evidence

```
$ curl -I http://127.0.0.1/DVWA/config/ -> HTTP/1.1 200 OK
$ curl -I http://127.0.0.1/DVWA/database/ -> HTTP/1.1 200 OK

$ curl http://127.0.0.1/DVWA/config/
<title>Index of /DVWA/config</title>
  config.inc.php          2.4K
  config.inc.php.bak      2.4K
  config.inc.php.dist     2.4K
  reports/                [DIR]
```

Note: the reports/ subdirectory visible in the config listing was created by the assessor when dirsearch wrote its output file. It is not a component of the target application.

Impact

Directory indexing removes the need for an attacker to guess filenames. It directly exposed the backup configuration file recorded in OSINT-008 and the database resource files recorded in OSINT-009, neither of which would have been reliably discoverable through wordlist-based enumeration alone. Listings also disclose file sizes and modification times, which assist in identifying recently changed or unusually sized files.

Recommendations

- Disable directory indexing globally using Options -Indexes.
- Provide an index document in directories that must remain web-accessible.
- Relocate configuration and database directories outside the document root.

OSINT-007 — HTML Source Comment Disclosure

Finding ID	OSINT-007	Inherent Risk	Low
Category	Information Disclosure	Contextual Risk	Low

Description

Inspection of the application source identified numerous HTML comments containing developer hints, implementation notes and, in at least one case, a hard-coded value used by an application control. These comments are rendered into responses returned to the client.

Evidence

```
$ grep -Rni '<!--' /var/www/html/DVWA | head
vulnerabilities/bac/source/low.php      <!-- Hint: Cookies can be modified by users ... -->
vulnerabilities/bac/source/high.php:60 <!-- Hint: Session management is better, but still ... -->
vulnerabilities/bac/source/medium.php  <!-- Hint: This token check isn't very secure ... -->
vulnerabilities/fi/file4.php:11        <!-- You did an even better job to see this :) -->
vulnerabilities/captcha/index.php:75   <!-- **DEV NOTE** Response: 'hidd3n_valu3' &&
                                         User-Agent: 'reCAPTCHA' **/DEV NOTE -->
setup.php:160                          <!-- Create db button -->
```

Impact

Comments embedded in client-visible source disclose implementation detail that assists an attacker in understanding application logic. The developer note in the CAPTCHA module is the most significant

example, as it discloses a hard-coded response value and the expected User-Agent string used by the control, which would materially reduce the effort required to bypass it. In DVWA these comments are intentional training hints, but the same pattern in a production application would constitute a genuine disclosure weakness.

Recommendations

- Remove developer comments from client-facing markup during the build process.
- Never embed credentials, tokens or expected control values in comments.
- Add a build or CI step that strips comments from production output.

OSINT-008 — Exposed Backup Configuration File

Finding ID	OSINT-008	Inherent Risk	High
Category	Information Disclosure	Contextual Risk	Medium

Description

A backup copy of the application configuration file is present and web-accessible at `/DVWA/config/config.inc.php.bak`. It was identified both through the directory listing described in OSINT-006 and through a targeted filesystem search for backup file extensions. Because the `.bak` extension is not mapped to the PHP interpreter, the file is returned as plaintext rather than being executed.

Evidence

```
$ find /var/www/html/DVWA -type f \( -name "*.bak" -o -name "*.old" -o -name "*~" \)
/var/www/html/DVWA/config/config.inc.php.bak
# Confirmed present in the directory index:
Index of /DVWA/config
config.inc.php
config.inc.php.bak      <-- served as plaintext
config.inc.php.dist
```

Impact

The DVWA configuration file defines the database hostname, database name, and the username and password used by the application to connect to MariaDB. Because the backup copy is served as plaintext rather than executed, these credentials are disclosed directly to any client that requests the file. Combined with the database service identified in OSINT-002, this creates a complete path to the application database that entirely bypasses application-layer authentication and access control. This is assessed as the most directly exploitable finding of the assessment.

Recommendations

- Remove all backup files from web-accessible directories immediately.
- Store backups outside the document root, with access restricted to administrative users.
- Deny access to backup extensions at the web server level, for example `.bak`, `.old` and `.orig`.
- Rotate the disclosed database credentials.
- Add a pre-deployment check that fails the build when backup artefacts are present in the document root.

OSINT-009 — Exposed Database Resource Files

Finding ID	OSINT-009	Inherent Risk	Medium
Category	Information Disclosure	Contextual Risk	Medium

Description

The /DVWA/database/ directory is web-accessible with indexing enabled and exposes database provisioning scripts for five database platforms, together with two SQLite database files.

Evidence

```
$ curl http://127.0.0.1/DVWA/database/
<title>Index of /DVWA/database</title>
  bac_setup.sql           1.0K
  create_mssql_db.sql     1.1K
  create_oracle_db.sql    1.1K
  create_postgresql_db.sql 810
  create_sqlite_db.sql    945
  sqli.db                 20K
  sqli.db.dist            20K
```

Impact

Database creation scripts disclose the application schema, including table names, column names and data types. This removes the need for an attacker to infer schema structure during SQL injection testing, allowing precisely targeted payloads to be constructed immediately. The SQLite database files are directly downloadable and may contain seed or practice data. Schema disclosure substantially reduces the effort required to exploit the injection modules identified in RQ-04.

Recommendations

- Relocate database provisioning scripts outside the web root.
- Deny web access to .sql and .db file extensions.
- Disable directory indexing as described in OSINT-006.

OSINT-010 — JavaScript Comment Disclosure

Finding ID	OSINT-010	Inherent Risk	Informational
Category	Information Disclosure	Contextual Risk	Informational

Description

Comments within the application JavaScript files disclose implementation detail, including a commented-out call to the eval function that indicates historical use of dynamic code evaluation.

Evidence

```
$ grep -Rni "/" /var/www/html/DVWA/dvwa/js
dvwaPage.js:7 //eval("page" + id + " = window.open(URL, ...);
dvwaPage.js:27 // Guestbook form
add_event_listeners.js:1 // These functions need to be called after the content they reference
add_event_listeners.js:2 // has been added to the page otherwise they will fail.
```

Impact

The commented eval call indicates that dynamic code evaluation was used in this file at some point in its history. While the call is inactive, it signals a code pattern worth examining during source review in Phase 2, particularly in relation to the DOM-based cross-site scripting module. The remaining comments disclose minor structural information about page initialisation.

Recommendations

- Strip comments from JavaScript as part of a minification or build step.
- Remove commented-out code rather than retaining it in deployed files.

OSINT-011 — Web Crawler Policy Disclosure

Finding ID	OSINT-011	Inherent Risk	Informational
Category	Information Disclosure	Contextual Risk	Informational

Description

A robots.txt file is present and readable at /DVWA/robots.txt. The file instructs all crawlers to avoid the entire application path.

Evidence

```
$ cat /var/www/html/DVWA/robots.txt
User-agent: *
Disallow: /
```

Impact

The file applies a blanket disallow rule and does not enumerate any hidden or sensitive paths, so it provides no additional reconnaissance value to an attacker. It is recorded for completeness because robots.txt review is an explicit requirement of RQ-05. It is worth noting that robots.txt is only advisory and provides no access control; the directories excluded from crawling remain fully accessible to direct requests.

Recommendations

- No remediation required for the current contents.
- Never rely on robots.txt as an access control mechanism.
- Avoid listing sensitive paths in robots.txt, as the file is publicly readable.

6. Attack Surface Summary

The table below consolidates all identified attack surface components. Entry point identifiers correspond to those used in the attack surface diagram and entry point matrix in Section 4.6.

ID	Component	Location	Description	Risk
NET-01	HTTP web service	80/tcp	Apache 2.4.68; primary delivery channel for all web attacks	Medium
NET-02	Database service	3306/tcp	MariaDB 11.8.8; bound to localhost	Medium
AS-01	Login page	/DVWA/login.php	Authentication entry point; PHPSESSID session handling	Medium
AS-02a	Configuration directory	/DVWA/config/	Directory listing enabled	Medium
AS-02b	Backup configuration file	/DVWA/config/config.inc.php.bak	Plaintext database credential disclosure	High
AS-02c	PHP configuration file	/DVWA/php.ini	Readable configuration; directives not applied at runtime	Medium
AS-03	Database resources	/DVWA/database/	SQL provisioning scripts and SQLite databases	Medium
AS-04	Source control metadata	/DVWA/.git/	Full repository metadata readable over HTTP	High
AS-05	Vulnerability modules	/DVWA/vulnerabilities/	19 modules across five vulnerability classes	High
AS-06	Administrative interface	/DVWA/setup.php	Database creation and credential reset	Medium
AS-07	File upload component	/DVWA/vulnerabilities/upload/	Accepts user-supplied files	High
AS-08	API component	/DVWA/vulnerabilities/api/	API module; endpoints not enumerable passively	Medium
INF-01	HTML source comments	Application-wide	Developer hints and hard-coded control values	Low

Prioritized Attack Chains for Phase 2

The following chains combine individual findings into realistic attack paths and represent the recommended order of investigation during the Phase 2 vulnerability assessment.

Priority	Chain	Outcome
1	AS-04 (/ .git/) → reconstruct application source	Converts black-box testing to white-box review of all modules
2	AS-02b (.bak credentials) → NET-02 (MariaDB 3306)	Direct database access bypassing application controls
3	AS-03 (schema disclosure) → AS-05 (sqli, sqli_blind)	Precisely targeted SQL injection payloads
4	AS-02c (verify runtime config) → AS-05 (fi)	Determine whether inclusion is local only or remote
5	INF-01 (CAPTCHA dev note) → AS-05 (captcha)	Control bypass using disclosed hard-coded value

7. Conclusion

Phase 1 reconnaissance against the DVWA target has been completed successfully. The assessment established a complete profile of the target environment using passive and non-exploitative techniques only, and every conclusion drawn is supported by recorded command output or screenshot evidence.

The technology stack was fingerprinted with a high degree of confidence: Apache 2.4.68 on a Debian-based host, PHP 8.4.23, MariaDB 11.8.8, and an HTML5 front end with no framework or content management system in use. Two network services were enumerated, and fifteen application resources and nineteen vulnerability modules were catalogued.

Eleven information disclosure findings were identified and validated. Two carry High inherent risk: the exposed Git repository, which permits full source code reconstruction, and the exposed backup configuration file, which discloses database credentials in plaintext. A recurring theme across the findings is that sensitive files are present inside the web root and are served directly because directory indexing is enabled and no extension-based access restrictions are configured. Addressing these two systemic issues, rather than each file individually, would eliminate the majority of the disclosure findings in this report.

It should be noted that DVWA is deliberately insecure by design and is deployed here in an isolated laboratory environment. The findings are therefore expected, and the value of this phase lies in the completeness of the resulting attack surface model rather than in the novelty of the weaknesses identified.

Preparation for Phase 2

The attack surface model produced in this phase provides a directly actionable testing scope for the Phase 2 vulnerability assessment. The following activities are recommended, in priority order:

- Reconstruct the application source from the exposed Git repository and perform a white-box review of the highest-risk modules.
- Validate the database credentials disclosed in the backup configuration file and assess the extent of data accessible through the database service.
- Test the injection modules using the schema recovered from the exposed database provisioning scripts.
- Re-verify the effective PHP runtime configuration before conducting file inclusion testing.
- Perform authenticated enumeration of the API module, which could not be assessed passively.
- Confirm whether authentication rate limiting is enforced, which could not be tested within the Phase 1 scope.

8. Acceptance Criteria Compliance

The table below maps each Phase 1 acceptance criterion to the section of this report in which it is satisfied.

Acceptance Criterion	Status	Report Reference
Target environment identified and documented	Complete	Sections 3 and 4.1
Technology stack fingerprinted	Complete	Section 4.2
Network services enumerated	Complete	Section 4.3
Application resources discovered and catalogued	Complete	Section 4.4
Information disclosure analysis completed	Complete	Sections 4.5 and 5
Attack surface mapping performed	Complete	Sections 4.6 and 6
All findings supported by evidence	Complete	Section 5 and Appendix A
Professional assessment report produced	Complete	This document

Requirement	Deliverables Required	Status
RQ-01	Target Profile; Environment Details	Delivered
RQ-02	Technology Stack Inventory; Evidence Screenshots	Delivered
RQ-03	Port Enumeration Report; Service Inventory; Supporting Evidence	Delivered
RQ-04	Resource Inventory; Endpoint Inventory; Evidence Repository	Delivered
RQ-05	Information Disclosure Findings; Risk Assessment; Evidence	Delivered
RQ-06	Attack Surface Inventory; Entry Point Matrix; Attack Surface Diagram	Delivered

Appendix A — Evidence Index

All evidence was collected on 2 August 2026 from the assessment host. Screenshots are reproduced in the body of this report at the point of first relevance; this index provides a consolidated reference.

Ref	Evidence	Command / Source	Supports
E-01	Apache service status	systemctl status apache2	Section 3, RQ-01
E-02	MariaDB service status	systemctl status mariadb	Section 3, RQ-03
E-03	DVWA home page	Browser — /DVWA/index.php	RQ-01
E-04	DVWA setup check	Browser — /DVWA/setup.php	RQ-02, OSINT-005
E-05	HTTP response headers	curl -I /DVWA/login.php	RQ-02, OSINT-001, 004
E-06	WhatWeb fingerprint	whatweb http://127.0.0.1/DVWA	RQ-02
E-07	JavaScript file inventory	ls -la /DVWA/dvwa/js; find	RQ-02
E-08	Nmap service scan	nmap -sV 127.0.0.1	RQ-03, OSINT-002, 004
E-09	dirsearch enumeration	dirsearch -u http://127.0.0.1/DVWA/	RQ-04, OSINT-003
E-10	robots.txt and module list	cat robots.txt; find vulnerabilities	RQ-04, OSINT-011
E-11	Git directory validation	curl -I /DVWA/.git/	OSINT-003
E-12	php.ini exposure	curl -I and curl /DVWA/php.ini	OSINT-005
E-13	config directory validation	curl -I /DVWA/config/	OSINT-006
E-14	database directory validation	curl -I /DVWA/database/	OSINT-006
E-15	config directory listing	curl /DVWA/config/	OSINT-006, 008
E-16	database directory listing	curl /DVWA/database/	OSINT-006, 009
E-17	HTML comment disclosure	grep -Rni comments across web root	OSINT-007
E-18	JavaScript comments and backup search	grep -Rni; find -name "*.bak"	OSINT-008, 010

Evidence Handling Notes

- Session identifier values visible in HTTP response headers were redacted by the assessor before the evidence was recorded.
- One command (the initial HTML comment search) failed due to shell history expansion of the exclamation mark in the search pattern. The command was corrected and re-executed successfully; only the successful execution is reproduced as evidence.
- The reports/ directory visible in the config directory listing is an assessor-created artefact produced by dirsearch output and is not a component of the target application.